CLAUDE CERTIFIED ARCHITECT — PROFESSIONAL

Domain 5: Governance, Safety & Risk Management

Exam objectives covered

1. Implement guardrails and safety controls spanning input validation and screening, output validation, prompt injection protection, jailbreak prevention, tool permission restrictions, system prompt guardrails, deterministic enforcement through code, monitoring and incident detection, and fail-open versus fail-closed behaviour.
2. Identify risks, limitations and failure modes including hallucinations, biased outputs, prompt injection, indirect prompt injection through retrieved documents, sensitive data leakage, excessive permissions, unreliable agent behaviour, runaway agent execution, model deprecation and retirement, and context and token exhaustion.
3. Apply human-in-the-loop validation, including mandatory approval before high-risk actions, human review after execution for reversible actions, confidence-based escalation, exception handling, human review queues, risk-based review strategies, and audit trails and approval records.
4. Ensure regulatory compliance across frameworks such as GDPR, HIPAA, and FedRAMP, covering data privacy and protection, data retention, data residency, access controls, auditability, deployment-specific compliance requirements, and how the chosen deployment platform affects compliance obligations.
5. Address ethical AI considerations including bias detection, fairness, transparency, explainability, responsible AI, accountability, user disclosure, and monitoring discriminatory outcomes.

Q1 **A regional insurance carrier's Claude-based claims agent has a tool that approves payouts and a system prompt stating "never approve claims above $10,000 without supervisor sign-off." A penetration tester crafts a prompt that convinces the agent to approve a $25,000 claim. What does this demonstrate, and what is the correct fix?**

A The model needs a longer, more emphatic system prompt

B **Prompt-only guardrails are insufficient for high-risk actions; the payout tool itself must enforce a hard, deterministic ceiling and require a verified supervisor-approval token before executing any claim above the threshold**

C The agent should be retrained on more insurance claims data

D The incident should simply be logged for quarterly review with no immediate change

CORRECT ANSWER **B**

WHY This is the central architectural principle of Domain 5: prompts alone cannot guarantee enforcement of a rule — deterministic code-level controls (tool-level limits, mandatory approval tokens) are what actually prevent the unauthorized action. A, C, and D fail to close the gap that allowed the bypass.

Q2 **A hospital's AI-assisted intake tool ingests referral letters via RAG. One letter contains hidden instructions attempting to get Claude to recommend an unapproved medication. Separately, the tool hallucinated a nonexistent lab reference range in another case last month. How should the architecture team categorize and address these two distinct issues?**

A Both are the same risk (hallucination) and can be fixed with one fine-tuning pass

B **The first is indirect prompt injection via untrusted retrieved content (addressed by content isolation and restricting actionable instructions from documents), and the second is hallucination (addressed by grounding outputs in verified medical reference data with validation)**

C Both should be ignored since they are rare edge cases

D Both can be fully solved by adding a stronger system prompt disclaimer

CORRECT ANSWER B

WHY These are distinct failure modes requiring distinct mitigations: indirect injection needs content-provenance/isolation controls, while hallucination needs grounding and validation against trusted sources. A, C, and D either conflate the issues or rely on insufficient prompt-only fixes.

Q3 **A SaaS company's DevOps agent can run infrastructure changes. The team sets up a policy: low-blast-radius changes auto-apply, while changes to production security groups require two-person human sign-off recorded in a ticketing system before the agent's apply tool will execute. What combination of Domain 5 principles does this reflect?**

A Pure ethical AI consideration only

B **A risk-based human-in-the-loop review strategy combined with deterministic enforcement — the apply tool itself checks for a recorded approval before executing high-risk changes — plus an audit trail via the ticketing system**

C Regulatory compliance only, unrelated to safety

D Bias mitigation only

CORRECT ANSWER B

WHY This scenario combines a risk-tiered human-in-the-loop strategy with deterministic, code-enforced gating (the tool checks for approval) and audit-trail recordkeeping — illustrating how these Domain 5 concepts work together in practice. A, C, and D each capture only an unrelated or incomplete slice of what's happening.

Q4 **A multinational bank's fraud-detection assistant must comply with GDPR for EU customers and also avoid discriminatory outcomes across demographic groups. An audit reveals the tool flags transactions from a particular immigrant community at a disproportionately higher rate not explained by actual fraud base rates. What combined response is required?**

A Treat this purely as a GDPR data-residency issue

B **Treat this as both a fairness/discriminatory-outcome issue requiring bias investigation and remediation, and a compliance issue requiring documentation of the corrective action and ongoing monitoring for the audit trail required by regulators**

C Dismiss the finding since fraud detection is inherently statistical and disparities are expected

D Resolve it solely by deleting the demographic data from the training set with no further action

CORRECT ANSWER **B**

WHY This scenario sits at the intersection of ethical AI (discriminatory outcome monitoring and bias remediation) and regulatory compliance (documented corrective action and auditability), both of which must be addressed together. A mischaracterizes the issue, and C and D are inadequate, superficial responses.

Q5 **A government agency deploying a Claude-based benefits chatbot must satisfy FedRAMP authorization requirements while also ensuring the chatbot discloses to users that they are interacting with an AI. Which statement correctly distinguishes these two obligations?**

A They are the same requirement under a different name

B FedRAMP authorization concerns the security posture and authorization of the underlying cloud/deployment environment, while AI disclosure is a separate transparency/ethical-AI and often legal obligation to inform users they are interacting with an automated system — both must be satisfied independently

C Satisfying FedRAMP automatically satisfies AI disclosure requirements

D Neither applies to government chatbots handling only "general information" queries

CORRECT ANSWER B

WHY FedRAMP is an infrastructure/security authorization framework, while user disclosure of AI involvement is a distinct transparency obligation — architects must address both as separate requirements. A and C incorrectly conflate them, and D incorrectly assumes an exemption.

Q6 **A logistics company's autonomous route-optimization agent begins making thousands of rapid-fire calls to a third-party mapping API after an edge case in traffic data causes a reasoning loop. What immediate deterministic safeguard should have been in place, and what risk does this situation best exemplify?**

A Bias; the fix is retraining on more traffic data

B **Runaway agent execution; the fix is enforcing hard iteration/call-count limits, timeouts, and circuit breakers in the code surrounding the agent, independent of the model's own reasoning**

C Model deprecation; the fix is switching providers

D Sensitive data leakage; the fix is encrypting map data

CORRECT ANSWER **B**

WHY Uncontrolled repeated tool invocation due to a reasoning loop is the definition of runaway agent execution, which must be bounded by deterministic circuit breakers rather than hoping the model self-corrects. A, C, and D misidentify the risk category.

Q7 **A healthcare system wants its Claude-based clinical assistant to both (a) never allow unauthorized staff to view a patient's psychiatric treatment notes (subject to extra confidentiality protections under some state laws) and (b) maintain a complete audit trail for HIPAA compliance. What is the correct way to design for requirement (a)?**

A. A system prompt instructing Claude to "never reveal psychiatric notes to unauthorized staff"

B. Backend role-based access control that filters which records (including the extra-protected psychiatric notes) are even retrievable by a given user's session, enforced before any data reaches the model, combined with access logging for audit purposes

C. Asking Claude to check the user's job title before answering

D. Relying on staff's professional ethics training alone

CORRECT ANSWER B

WHY Confidential data protection must be enforced via backend authorization/access control at the data-retrieval layer — ensuring the model never even receives data the requesting user isn't authorized to see — combined with logging for the audit trail obligation. A, C, and D all rely on non-deterministic, bypassable mechanisms.

Q8 **A manufacturing company's quality-control agent occasionally encounters defect patterns it has never seen before. The team designed it to route "unknown pattern" cases to a human inspector rather than guessing. Separately, the company must retain inspection records for seven years under industry regulation. What two Domain 5 concepts does this combined design address?**

A Only regulatory compliance

B **Exception handling within a human-in-the-loop design (routing unfamiliar cases to humans) combined with a regulatory data-retention requirement (seven-year record retention), both of which require deliberate architectural support**

C Only ethical AI considerations

D Only guardrails against prompt injection

CORRECT ANSWER **B**

WHY This scenario combines a human-in-the-loop exception-handling pattern (escalating out-of-scope cases) with a distinct regulatory retention obligation — both are separate Domain 5 concerns that happen to appear together here. A, C, and D each capture only part of the picture.

Q9 **A telecom's customer support chatbot has no classifier or rules layer screening incoming messages, relying entirely on the system prompt to refuse jailbreak attempts. After several successful jailbreaks are reported, what is the best remediation strategy reflecting defense-in-depth?**

A Add one more sentence to the system prompt emphasizing refusal

B **Add an independent input-screening layer (classifier/rules) ahead of the model, combine it with output validation, and restrict sensitive tool permissions, so that no single bypassed layer compromises the whole system**

C Disable the chatbot permanently

D Switch to a model with a larger context window

CORRECT ANSWER **B**

WHY The appropriate fix is layered, deterministic defenses (input screening, output validation, tool permission limits) rather than further strengthening a single prompt-based layer, which has already been shown to be bypassable. A repeats an approach that failed, and C and D don't address the root architectural gap.

Q10 **A financial advisory platform wants its AI-assisted investment recommendations to be both explainable to customers and defensible to regulators during an audit. What single architectural feature best supports both goals simultaneously?**

A. A generic disclaimer stating "results may vary"

B. Tying each recommendation to specific, retrievable underlying factors (e.g., risk tolerance inputs, relevant market data) presented in a structured, human-readable format, with the full decision trail logged for audit purposes

C. Keeping the model's reasoning entirely hidden to protect intellectual property

D. Explaining decisions only when a regulator formally requests it, with no routine documentation

CORRECT ANSWER B

WHY Structured, factor-based explainability that's also logged provides both customer-facing transparency and regulator-facing auditability from a single underlying design. A is non-substantive, and C and D fail to provide the transparency and proactive documentation needed in a regulated context.

Q11 A retail company's agent has access to a "cancel_subscription" tool. During a chaos-engineering exercise, testers discover that even without any prompt manipulation, the agent occasionally calls this tool mistakenly due to ambiguous phrasing in customer messages ("I want to cancel... actually no, never mind the cancellation, cancel my concern instead"). What is the most robust mitigation?

A Rely on the model to parse ambiguous phrasing perfectly in the future

B Require the cancel_subscription tool to prompt for an explicit, unambiguous confirmation step (human-in-the-loop-style double-check) before executing, regardless of how confident the agent's language parsing appears

C Remove the cancellation feature entirely so customers must call in

D Add a system prompt note asking Claude to "be extra careful with cancellations"

CORRECT ANSWER B

WHY Since natural language ambiguity is an inherent model limitation (not fixable through prompting alone), adding a deterministic confirmation/safety step for irreversible actions is the right mitigation — an application of human-in-the-loop-style validation even for customer self-service actions. A and D rely on unreliable model behavior, and C removes useful functionality unnecessarily.

Q12 **A government contractor's AI governance board wants evidence that their Claude-based procurement-scoring tool has not introduced discriminatory bias against small or minority-owned businesses over the past year. What is the most appropriate ongoing practice to provide this evidence?**

A. A one-time fairness review conducted before the tool's initial launch

B. Periodic, structured outcome audits comparing scoring patterns across business ownership categories over time, with documented findings and corrective actions feeding into the compliance audit trail

C. Relying on the vendor's assurance that the model is "unbiased by design"

D. Removing business ownership category data from all records to avoid the appearance of bias

CORRECT ANSWER B

WHY Demonstrating the absence of discriminatory drift requires ongoing, periodic structured audits with documented findings — both an ethical-AI monitoring practice and a compliance/auditability requirement. A is a one-time snapshot, and C and D either rely on unverified claims or eliminate the very data needed to detect bias.

Q13 **A manufacturing company's Claude agent has a tool to adjust safety-critical machine calibration. Leadership wants to allow the agent to propose adjustments quickly but insists no adjustment takes effect without an engineer's explicit approval, and every approval must be retrievable for a safety audit two years later. Which combination of controls satisfies all stated requirements?**

A A system prompt instructing the agent to "ask before adjusting"

B **The calibration-adjustment tool itself rejects any call lacking a verified engineer-approval record, and all approval records are persisted in durable, queryable storage for at least two years**

C A verbal confirmation process with no digital record

D Logging only successful adjustments, not the approval requests themselves

CORRECT ANSWER **B**

WHY This requires both deterministic pre-execution enforcement (the tool rejects unapproved calls) and durable, retrievable audit records meeting the specified retention period — a combination of human-in-the-loop enforcement and compliance/auditability design. A is advisory only, and C and D fail to provide the required durable, complete audit trail.

Q14 **A SaaS company deploying Claude through a specific cloud marketplace offering discovers that offering's default data handling terms permit the cloud provider to log and retain prompts for longer than the company's internal privacy policy allows. What should the architecture team do?**

A Ignore the discrepancy since the cloud provider's terms "probably don't matter in practice"

B **Investigate and negotiate or configure enterprise/zero-data-retention terms appropriate to the deployment platform, since the choice of deployment platform directly affects what data handling and compliance obligations can be met**

C Switch to recording conversations manually instead of using the platform's built-in logging

D Proceed without changes since prompts are not considered "data" under most regulations

CORRECT ANSWER **B**

WHY This is a direct illustration of how deployment-platform choice affects compliance obligations — architects must verify and actively configure data handling terms (e.g., enterprise/zero-retention agreements) to align with internal and regulatory requirements. A, C, and D all underestimate or misunderstand the real compliance exposure.

Q15 **A legal tech company's contract-review assistant flags clauses below a confidence threshold for paralegal review, while high-confidence clauses pass through automatically. Separately, the company must disclose to clients that AI assisted in the review. Which statement best describes how these two practices relate to Domain 5 principles?**

A They are redundant and only one is actually necessary

B **The confidence-based escalation is a human-in-the-loop risk-management practice addressing model reliability, while the client disclosure is a distinct transparency/ethical-AI obligation about informing users of AI involvement — both are necessary and address different risks**

C Both practices exist solely to satisfy FedRAMP

D Confidence-based escalation makes client disclosure unnecessary since humans are already involved

CORRECT ANSWER B

WHY These are complementary but distinct Domain 5 practices: one manages model-reliability risk through tiered human review, and the other satisfies a transparency/disclosure obligation to end users regardless of how much human review occurs internally. A, C, and D all incorrectly conflate or dismiss one of the two necessary practices.

Q16 An e-commerce company's Claude agent has tool access to issue refunds, update shipping addresses, and query order history. A security review recommends splitting these into separately permissioned tools and granting the refund tool only to sessions handling confirmed support tickets, rather than giving every session access to all three capabilities. What principle is being applied, and why does it matter even though the agent "behaves correctly" in current testing?

A. This is unnecessary over-engineering since current testing shows no problems

B. This applies least-privilege/excessive-permissions mitigation: scoping tool access narrowly reduces the potential blast radius if the agent is later manipulated via prompt injection or encounters an unanticipated failure mode, even if it behaves correctly today

C. This is purely a performance optimization unrelated to safety

D. This is only relevant for regulatory compliance, not for safety

CORRECT ANSWER B

WHY Least-privilege tool scoping is a core safety/risk-management principle precisely because current correct behavior does not guarantee future robustness against injection attacks or edge cases — reducing available capabilities reduces potential harm regardless of present performance. A, C, and D all understate the ongoing risk-mitigation value of this practice.

Q17 **A healthcare company enables an enterprise Zero Data Retention arrangement and HIPAA readiness (with a signed BAA) for its Claude-based patient-messaging assistant. Separately, its human-review process routes any flagged message for physician sign-off based on the dollar value of the associated billing code rather than on whether an incorrect message could cause irreversible harm to the patient. An architecture review flags two independent problems. What are they?**

A. There is only one problem: the ZDR/BAA setup is sufficient on its own and needs no further action

B. **First, ZDR and HIPAA-readiness coverage must be verified feature-by-feature rather than assumed to apply to every capability the assistant uses; second, routing human review by billing-code dollar value is the wrong axis — review should be routed by whether the message's potential harm is irreversible and how far it could spread, not by transaction size**

C. Both problems are purely regulatory and have no bearing on human-in-the-loop design

D. Neither is a real problem since HIPAA readiness guarantees blanket coverage and dollar value is always a valid proxy for risk

CORRECT ANSWER B

WHY This combines two distinct Domain 5 pitfalls: assuming a compliance arrangement (ZDR/BAA) automatically covers every feature in use, and routing human review by a size-based proxy instead of the correct reversibility/blast-radius axis — both must be corrected independently. A and D wrongly assume both setups are already adequate, and C incorrectly treats the human-review flaw as a regulatory-only issue.

Q18 **An insurance company's claims chatbot has its safety classifier hardened after a jailbreak incident, but nobody is tracking whether the hardened classifier now blocks legitimate claims questions, and the application still treats every HTTP 200 response as a trustworthy answer without checking for a refusal signal. What combination of gaps does this illustrate?**

A A single gap: the classifier is too strict and should simply be loosened

B **Two distinct guardrail-quality gaps: the team is not measuring the classifier's false-refusal (over-refusal) rate against legitimate requests to verify it is correctly tuned, and the application is not instrumenting the response's `stop_reason` to detect refusals, so genuine refusal events are silently mishandled**

C Only a regulatory compliance gap, since classifiers are a legal requirement rather than a technical one

D Only a bias/fairness gap, since classifier strictness varies by user

CORRECT ANSWER B

WHY These are two separate, commonly paired guardrail-engineering gaps: failing to measure over-refusal alongside catch-rate when tuning a classifier, and failing to detect refusal responses (which arrive as HTTP 200 with a distinct stop reason) so they can be handled correctly rather than displayed as normal answers. A oversimplifies to only one issue, and C and D misclassify the nature of the gaps.

Q19 **A credit-union's lending-support assistant tends to agree with loan officers' stated assumptions ("since this applicant's income history is obviously stable, approve the higher limit") rather than independently verifying them, and the union's compliance program has not yet determined which of the assistant's recommendations require a qualified reviewer's sign-off and applicant disclosure under high-risk AI recommendation rules. What should the architecture and governance teams address together?**

A Only the sycophancy issue; disclosure and qualified review only matter for fully automated systems, not human-assisted ones

B **Both issues: mitigate sycophancy by instructing and evaluating the assistant for appropriate disagreement rather than treating loan-officer agreement as validation, and separately classify which recommendations are "wholly favorable" (potentially exempt) versus partial/denied (requiring qualified-reviewer sign-off and applicant disclosure)**

C Neither issue needs attention since a human loan officer is already in the loop

D Only the disclosure issue; sycophancy is a harmless style preference with no risk implications

CORRECT ANSWER **B**

WHY These are two separate Domain 5 concerns that commonly co-occur: sycophancy is a model-reliability failure mode requiring explicit evaluation for independent judgment, while the qualified-review/disclosure obligation is a distinct ethical-AI and policy requirement that depends on whether an outcome is wholly favorable or not — both must be addressed, and the presence of a human in the loop does not by itself satisfy either. A, C, and D each dismiss one of the two necessary fixes.